

OmniFlow — Phase 2 (CommBot) Final Grade

Auditor: Principal Engineering Council (Sentinel loop) **Scope:** `services/commbot/` — core domain, inbound Kafka adapter, outbound LLM adapter, composition root, consumer-side persistence **Date:** 2026-07-21 **Verdict:**  **PASS (A-)** — runnable, production-shaped, review-grade (not yet CI-compiled)

Grade by area

Area	Grade	Notes
Hexagonal isolation	A	Domain imports no Kafka/Protobuf; ports own the boundary; adapters do all mapping.
Inbound Kafka adapter	A-	Confirmed-delivery DLQ, in-place bounded retry (correct offset semantics), real W3C trace extraction, nil-safe mapping, bounded poll for graceful shutdown.
Outbound LLM adapter	A-	SSRF allowlist + private-IP block, proactive <code>x/time/rate</code> token bucket, real response parsing, typed transient/terminal errors.
Data integrity	A	No dual-write: idempotency claim + classified-event outbox commit in one CRDB tx; changefeed emits onward.
Telemetry	B+	OTel wired end-to-end incl. traceparent propagation; span coverage good. Metrics (RED) not yet added.

Area	Grade	Notes
Build verification	C	No Go toolchain in the audit session — files are review-grade, not <code>go build/go vet</code> verified.

What was fixed this phase (history)

- **Domain watch-items** (all closed): injected `TracerProvider`, nil guard, no in-place mutation.
- **Adapter Red-Team FAIL** → **corrected**: fake hardcoded classification, open SSRF, no rate limiting, fire-and-forget DLQ + premature commit, broken Kafka retry/offset semantics, no-op traceparent extraction, nil-timestamp panic, missing idempotency, `%v` error-chain break.
- **Runnable-service gaps** → **closed now**: composition root (`cmd/main.go`), transactional outbox `Publisher` + `IdempotencyStore` (`crdb/repository.go`), consumer-side schema + changefeed (`commbot_outbox_schema.sql`).

Residual risks (carry into Phase 2.5 / hardening)

1. **Not CI-verified**. Pin `go.mod` and run `go build ./... && go vet ./...`. Version-sensitive: `protovalidate.New()`, confluent-kafka-go `Poll`, OTel `semconv` / `otlptracehttp`, pgx v5.
2. **New deps to add**: golang.org/x/time/rate, github.com/jackc/pgx/v5, OTel SDK + OTLP HTTP exporter.
3. **Duplicate LLM spend under concurrency** is possible (claim happens at publish, not pre-LLM). Documented tradeoff; upgrade to a `processing` claim (saga) if spend matters.
4. **DNS-rebind TOCTOU** in the SSRF check — pin the resolved IP via `net.Dialer.Control` for hard guarantees.
5. **Dedicated `EmailClassified` proto** would be cleaner than reusing `VendorEmailReceived` for the onward event.
6. **No RED metrics / consumer-lag alerting yet**.

Gate decision

Phase 2 is **cleared to proceed to Phase 3 (P2P Orchestrator)**, conditional on a green `go build/go vet` and `go.mod` pinning before any Phase 2 code is demoed.